POS, bankcard, and acquiring processing facilities to ensure appropriate physical and logical access controls are in place.

H. ACH ODFI and RDFI Responsibilities

1. Determine whether agreements between the ODFI and originators adequately address

- Liabilities and warranties,
- Responsibilities for processing arrangements, and
- Other originator obligations such as security and audit requirements.

2. Determine whether the ODFI has established procedures to monitor the creditworthiness of its originator customers on an ongoing basis. Determine whether:

- The ODFI assigns credit ratings to originators.
- Competent credit personnel perform monitoring, independent of ACH operations.
- Written agreements with originators require the submission of periodic financial information.

3. Determine whether the ODFI has established ACH exposure limits for originators. Determine whether:

- The limit is based on the originator's credit rating and activity levels.
- The limit is reasonable relative to the originator's exposure across all services (lending, cash management, foreign exchange, etc.).
- Limits have been established for originators whose entries are transmitted to the ACH operator by a technology service provider.
- Written agreements with originators address exposure limits.
- A separate limit for WEB entries and other high-risk ACH transactions, as warranted, has been established.

4. Determine whether the ODFI reviews exposure limits periodically. Determine whether:

- The ODFI adjusts limits for changes in an originator's credit rating and activity levels.

- Increases in an originator's ACH debit return volume trigger a re-evaluation of the exposure limit.
- The ODFI reviews the limits in conjunction with the review of an originator's exposure limit across all services.

5. Determine whether the ODFI has implemented procedures to monitor ACH entries initiated by an originator relative to its exposure limit across multiple settlement dates. Determine whether:

- The monitoring system is automated and accumulates entries for a period at least as long as the average ACH debits return time (60-75 days).
- Entries in excess of the exposure limit receive prior approval from a credit officer.
- WEB entries and other high-risk ACH transactions (as warranted) are accumulated and monitored separately, yet integrated into the overall ACH transaction monitoring system.

6. Assess the RDFI's overdraft and funds availability policies and practices and determine whether they adequately mitigate its credit exposures to ACH transactions.

7. Determine the adequacy of the ODFI's practices regarding originators' annual or more frequent security audits of physical, logical, and network security. Determine whether:

- The ODFI receives summaries or full audit reports from the originators.
- The audits are adequate in scope and performed by independent and qualified personnel.
- Corrective actions regarding exceptions are satisfactory.

8. Determine how the ODFI or RDFI manages its relationship with technology service providers. Determine whether:

- The service provider's financial information is obtained and satisfactorily analyzed.
- Service-level agreements are established and monitored.

9. Determine whether the ODFI allows technology service providers direct access to an ACH operator. Consider whether agreements between the ODFI and the service providers include:

- A requirement that the service provider obtain the prior approval of the ODFI before originating ACH transactions for originators under the ODFI routing number.
- The establishment by the ODFI of dollar limits for files that the service provider deposits with the ACH operator.
- A provision that restricts the service provider's ability to initiate corrections to files that have already been transmitted to the ACH operator.
- Provisions regarding warranty and liability responsibilities.
- Appropriate handling of files (physical and logical access controls).

10. Determine whether the RDFI has established procedures to deal with consumers' notifications regarding unauthorized or improperly originated entries or entries where authorization was revoked.

11. Determine whether the RDFI acts promptly on consumers' stop-payment orders.

12. Determine whether the RDFI has procedures that enable it to freeze proceeds of ACH transactions in favor of blocked parties (under OFAC sanctions) for whom the RDFI holds an account.

13. Determine whether the financial institution considers the volume of its uncollected ACH transactions as part of its liquidity risk management practices.

14. Determine whether management and personnel display adequate knowledge and technical skills in managing and performing duties related to ACH transactions.

15. Review results from the financial institution's NACHA rule compliance audit. Determine:

- The independence and competence of the party performing the audit.
- Whether the board or its committee reviewed and approved the audit.
- Whether responsibilities for high-risk entries, such as WEB, were included in the scope.
- Whether corrective actions on audit exceptions are satisfactory.

I. ACH Accounting and Transaction Processing

1. Assess the adequacy of logs maintained for ACH payments received from, and delivered to, each customer.

2. Assess the adequacy of the balancing procedures used for all ACH payments received and whether they include balancing to the aggregate payments sent to an ACH operator.

3. Determine whether the institution balances all payments received from an ACH operator to the aggregate of payments delivered to customers.

4. Determine whether the institution verifies and authorizes the source of all ACH files received for processing.

5. Determine whether the institution reconciles all general ledger accounts related to ACH activities on a timely basis.

6. Determine whether ACH supervisory personnel perform reconcilement and regularly review exception items.

7. Determine whether the institution reconciles the ACH activity and pending file totals daily with the ACH operator.

8. Assess the effectiveness of the reconcilement with third-party service providers preparing ACH transaction files and ensure daily reconciliation.

9. Assess the effectiveness of ACH holdover transactions and determine whether the institution adequately controls them.

10. Determine whether accounting staff reconciles individual outgoing ACH batches before merging them with other ACH transactions.

11. Determine whether there are separate accounts to control holdovers, adjustments, return items, rejects, etc. and whether they are periodically reconciled.

12. Assess the effectiveness of the investigation unit to address customer inquiries and control return items, rejected/unposted items, differences, etc. Determine whether the unit periodically generates aging reports of outstanding items for management.

13. Assess whether management adequately tracks exceptions to credit limit policies and legal contracts.

14. Determine whether exception reports (e.g., rejects, return items, and aging of open items) receive appropriate management attention.

15. Assess the adequacy of separation of duties throughout the ACH process including origination, data entry, adjustments, internal reconcilement, preparing general ledger entries, posting to customer accounts, investigations, and reconcilement with ACH operators.

16. Determine whether adjustments (e.g., added payments, stop payments, reroutes, and reversals) to original ACH instructions are received in an area that does not have access to the original data files.

17. Assess whether controls are appropriate for the adjustment process, including authorization (e.g., signature verification and callbacks on telephone instructions) and whether the institution maintains adequate records (e.g., logs and taping of telephone calls) of individuals making requests.

18. Determine the adequacy of the customer profile origination and change request process. Consider whether requests:

- Are in writing or equivalent confirmation for online activities.
- Identify the originating personnel.
- Document supervisory approval.
- Are verified by staff unable to make changes.

J. ACH Funding and Credit

1. Assess the adequacy of the process for releasing payments to an ACH operator, and determine whether assurances are obtained that sufficient collected funds (e.g., on deposit or prefunded) or credit facilities are available. The institution should monitor customer intraday and interday positions based on defined thresholds.

2. For third-party service providers contracted to process outgoing ACH transactions, determine whether there are procedures to monitor ACH activity and ensure that funds are collected (collected balances, prefunding, credit lines) before the institution settles with the ACH operator.

3. For prefunding arrangements in place for customers without credit lines, determine whether management blocks funds (held for disposition) or maintains them in separate accounts until the transaction date.

4. For non prefunded arrangements determine whether the institution places blocks on outgoing payments to deposit accounts, applies them as reductions to credit lines, or includes them in the overall funds transfer monitoring process.

5. Determine whether management approves payments resulting in extensions of credit lines or drawings against uncollected funds and retains documentation to support the approvals. Determine whether the institution performs credit assessments of customers originating large dollar volumes of ACH credit transactions. Credit assessments should also be reviewed periodically to evaluate creditworthiness of the customer and current economic conditions.

6. Determine whether management treats ACH debits deposited as uncollected funds and whether they monitor any draws against these funds for debits originated by high-risk customers.

7. Determine whether management approves draws against uncollected ACH deposits and maintains documentation to support approvals for debits originated by high-risk customers.

8. Determine the adequacy of Internet and telephone ACH transaction processing procedures and determine whether there are appropriate authentication controls and procedures to ensure the proper identities of parties invoking ACH transactions.

9. Assess the adequacy of management's risk assessment of ACH services in terms of the importance of this function to the overall corporate treasury services function.

10. Ensure that the financial institution obtains and analyzes all audits conducted by the ACH service provider, pursuant to the NACHA rule compliance audit requirement.

K. Web and Telephone-Initiated ACH Transactions

1. Determine whether the financial institution has adopted adequate policies and procedures regarding ACH transactions involving Internet-initiated (WEB) entries. Determine whether they:

- Are in writing and approved by the board or a designated committee.
- Adequately address ODFI or RDFI responsibilities.
- Establish management accountability.
- Include a process to monitor policy compliance.
- Include a mechanism for periodic reviews and updates.

2. Determine whether the ODFI has implemented telephone-initiated (TEL) ACH entries. Determine whether:

- There are significant return rates for these transactions.
- The institution adheres to NACHA guidelines concerning merchant management and their business practices.
- Written agreements are in place with all originators submitting TEL transactions, and include adequate consumer (receiver) authentication and authorization.
- The institution makes tape recordings of all consumer oral authorizations.
- The institution provides written notice to the consumer, prior to settlement date for the TEL entry, confirming the terms of the oral authorization.

3. Determine whether the ODFI requires its originator to employ a commercially reasonable method to authenticate the consumer/business. Determine whether:

- Documentation of the method is adequate.
- The frequency of the review of commercially reasonable standards is sufficient.

4. Determine whether the ODFI conducts risk assessments of its originators and whether they reflect a reasonable exercise of business judgment. Consider whether the risk assessment includes evaluations of:

- Receiver authorizations.
- Originator's Internet security capability, including;
  - Commercially reasonable fraudulent transaction detection systems and routing number verification,
  - Secure customer Internet sessions, and
  - Annual (or more frequent) security audits based on risk.
  - Frequency of risk assessments.
  - Documentation and approval standards.

L. ACH Contingency Plans

1. Evaluate the adequacy of the ACH contingency plan; determine whether the financial institution has tested it and whether it includes provisions for partial or complete failure of the system or communication lines between the institution, ACH operators, customers, and associated data centers.

2. Based on the volume and importance of ACH activity, evaluate whether the plan is reasonable and whether it provides for a reasonable recovery period.

3. Determine whether the institution duplicates or retains transaction files for input reconstruction for a minimum of 24 hours. Note that NACHA rules require the retention of all entries, including return and adjustment entries, transmitted to and received from the ACH for a period of six years after the date of transmittal.

4. Determine whether data and program files are adequately secured, retained, and backed up at off-premises facilities, including secured transport mechanisms for those resources.

5. Determine whether the center has established and tested procedures to recover and restore data under various contingency scenarios.

6. Determine whether the frequency and methods of testing contingency plans are adequate.

M. Check 21

(A more comprehensive set of examination procedures that are designed to test transactions can be found at the FFIEC Check 21 InfoBase at www.ffiec.gov/exam/check21/default.htm.)

1. Determine whether:

- The institution manages check return items effectively and whether there are significant numbers of return items.
- The institution records source-document images for recovery if the originals are lost

in transit.

- The institution reconciles batch-dollar totals after processing.
- Reject items are properly segregated from other work.
- Exception items are controlled and tracked adequately.
- Item processing duties are segregated appropriately.

2. If a financial institution has begun to image checks or retrieve imaged checks pursuant to Check 21, determine whether the institution has the following:

- Consumer awareness program.
- Customer service - training and education process.
- Procedures for expedited re-credit.
- Procedures to qualify returns of substitute checks.
- Procedures to identify duplicate checks.
- Procedures for statement preparation and processing.
- Procedures for item repair.
- Procedures for managing corporate customers wanting to submit substitute checks.

3. If the financial institution is a reconverting institution pursuant to Check 21, determine whether it has the following:

- Procedures to identify, measure, and monitor fraud risk.
- Security features for substitute checks.
- Procedures for retention and retrieval of original items.
- Procedures for identifying/controlling duplicate checks.
- Procedures or processes to control substitute check shrinkage.
- Procedures and processes to manage quality.
- Procedures and processes to manage endorsements (includes electronic).
- Procedures and processes to manage re-presentments.
- Procedures to ensure full MICR line is on all substitute checks.

- Procedures and processes to control cash letters.

4. If the financial institution accepts RCCs from retail business customers or payment processing customers, assess the appropriateness of, and adherence to, policies and procedures regarding customer due diligence, customer contracts, third-party service provider's due diligence, and activity/transaction monitoring. Consider the following elements relative to the institution's retail customers, its payment processing customers, and any processors' retail customers:

- Customer due diligence performed at the initiation and periodically throughout the business relationship, including;
    - Assessment of risk exposure associated with the customer's underlying business models;
    - Review of operational history of customer (e.g., length of time in business, relocations of operations, and business reputation);
    - Performance of background checks on customer's principals and/or key operators.
    - Execution of contracts with customers containing provisions addressing;
        - Customer's agreement to operate in accordance with applicable laws and regulations (i.e., FTC Telemarketing Rule, UCC provisions);
        - The parties' responsibilities and warrants under Regulation CC;
        - Customer activity and/or transaction parameters and limits, including expected/allowable unauthorized return levels;
        - Auditing and/or access rights to customers' marketing scripts and consumer authorization/verification files;
        - The financial institution's ability to terminate the business relationship.
    - Routine monitoring and reporting of customer activity and transaction levels, including:
        - The integrity and timeliness of MIS reports on individual and aggregate customer activity/transaction and exposure levels;
        - Established management accountability throughout the business line, including an established process to report monitoring conclusions and exceptions to executive management;
        - Periodic re-assessment of customer exposure and/or transaction limits in association with customer due diligence and contract reviews;
        - The application of independent quality assurance or internal audit reviews to customer relationships in general and to customer monitoring activities in particular;

- Performance of on-site verification of customer authorization files where warranted.

N. Remote Deposit Capture Risk Management

1. Identify the key elements of the RDC environment.

- Identify the bank staff, customers, and technology service providers (if applicable) involved in the RDC function. Obtain and review reports of RDC volume (number of transactions and dollar ranges) for the financial institution as a whole and for individual customers.
- Obtain and review the topology of the financial institution's network, and determine the components involved in the RDC process. Identify the network interfaces with customers using RDC and the technology controls in place.
- Obtain and review the financial institution's data flow or process flow diagram, including relationships with any third-party service providers (if applicable) and the relationships with RDC customers. Identify when the diagram was last updated, and assess whether it is consistent with the system currently implemented.
- Identify whether the RDC system has the following features or functionality:
  - Duplicate item detection.
  - Scanner options (simplex/duplex, MICR/OCR, franking/spraying, CAR/LAR, etc.).
  - Interoperability with existing systems and/or ancillary applications (e.g., QuickBooks).
  - MIS and reporting (audit logs, activity reports).
  - Image quality.
  - Ability to change routing number, account number, and amount.
  - Least-cost routing functionality (conversion into different payment stream).
  - ABA validations (to identify deposits drawn on US versus foreign financial institution).
  - Ability to integrate with BSA/AML systems and processes.
  - Ability to integrate with OFAC systems.
  - Integration with enterprise-wide BCP.
  - Information security (authentication, access controls, encryption, etc.).